

AMADEUS × N2SF

국가 망 보안체계 5단계 적용 분석

N2SF 적용 절차의 5단계에서 AMADEUS 도구의 활용 가능성 분석

Nplus Lab

2026. 02

1. 개요

본 문서는 AMADEUS(Advanced Threat Modeling & Analysis Platform) 도구가 「국가 망 보안체계(N2SF) 보안 가이드라인 1.0」(국가정보원·국가보안기술연구소, 2025.9)에서 제시하는 5단계 적용 절차의 각 단계에서 어떻게 활용될 수 있는지를 분석한 것이다.

AMADEUS는 정보서비스의 네트워크 아키텍처를 시각적으로 모델링하고, Alloy 정형 검증 엔진을 통해 서로 다른 보안등급(C/S/O) 간 발생 가능한 구조적 보안위협을 자동으로 식별하는 도구이다. 이를 통해 가이드라인이 제시하는 「위치-주체-객체」 모델링과 보안원칙 적용을 자동화한다.

1.1 N2SF 5단계 적용 절차

국가 망 보안체계는 각급기관의 정보화사업에 대한 자체 보안대책을 수립하는 데 활용하며, 다음의 5단계 절차로 수행된다.

단계	명칭	주요 내용
1단계	준비 (Prepare)	N2SF 적용계획 수립, 기관 업무·기능 분석, 업무정보 식별, 정보시스템 식별, 정보서비스 식별
2단계	C/S/O 등급분류 (Categorize)	업무정보 C/S/O 등급분류, 정보시스템 C/S/O 등급분류
3단계	위협식별 (Identify)	「위치-주체-객체」 모델링 및 C/S/O 평가, 보안원칙 적용, 보안위협 식별
4단계	보안대책 수립 (Select)	보안 요구사항 도출, 보안통제 선택 및 구현계획 수립
5단계	적절성 평가·조정 (Assess)	적절성 평가, 평가결과 협의·조정, 평가결과 확인

1.2 AMADEUS 도구 개요

AMADEUS는 다음과 같은 핵심 기능을 제공한다.

- 시각적 네트워크 아키텍처 모델링 (ReactFlow 기반)
- 시스템별 C/S/O 보안등급 및 보안구역(기밀/민감/공개/DMZ) 지정
- 시스템 간 연결(Connection)의 보안속성 정의 (암호화, 인증, 세션정책 등)
- Alloy 정형 검증 엔진을 통한 자동 위협 식별 (59개 검증 규칙)
- JS 기반 경량 검증기 (6개 규칙, 빠른 사전 검증)
- 26개 N2SF 보안통제 코드 카테고리로 위협 분류 및 보안대책 매핑
- Score Dashboard를 통한 보안 점수 시각화
- 모델 JSON Export/Import를 통한 산출물 관리

2. 단계별 상세 분석

2.1 제1단계: 준비 (Prepare)

준비 단계는 정보서비스에 대한 국가 망 보안체계 적용 시 필요한 기초적인 정보를 수집하고 제반 활동을 준비하는 단계로서, N2SF 적용계획 수립, 기관 업무·기능 분석, 업무정보 식별, 정보시스템 식별, 정보서비스 식별의 5개 주요활동으로 구성된다.

AMADEUS 활용 가능 영역

활동	AMADEUS 활용
[활동-1-4] 정보시스템 식별	캔버스에 시스템 노드를 배치하면서 정보시스템의 논리적·물리적 구성을 시각적으로 파악할 수 있다. 각 시스템의 속성(서버, 단말, 보안장비 등)을 지정하여 정보시스템 목록을 체계적으로 관리한다.
[활동-1-5] 정보서비스 식별	시스템 간 연결(Connection)을 정의하여 정보서비스의 구성과 구조를 분석한다. 데이터 흐름 모델링을 통해 사용 시나리오를 시각적으로 표현할 수 있다.

※ [활동-1-1] N2SF 적용계획 수립, [활동-1-2] 기관 업무·기능 분석, [활동-1-3] 업무정보 식별은 조직·행정적 활동으로서 도구의 직접 지원 범위 밖이다.

2.2 제2단계: C/S/O 등급분류 (Categorize)

C/S/O 등급분류 단계에서는 준비 단계에서 식별한 업무정보 및 정보시스템에 대해서 C(기밀), S(민감), O(공개)의 3개 보안등급으로 분류한다.

AMADEUS 활용 가능 영역

활동	AMADEUS 활용
[활동-2-1] 업무정보 C/S/O 등급분류	각 시스템 노드에 securityGrade 속성(Classified / Sensitive / Open)을 지정하여 업무정보의 보안등급을 시스템 단위로 반영한다.
[활동-2-2] 정보시스템 C/S/O 등급분류	시스템을 보안구역(기밀구역 / 민감구역 / 공개구역 / DMZ)에 배치하면 구역과 시스템 등급 간의 적합성을 자동으로 검증한다. 가이드라인의 동일등급·복수등급 분류 규칙을 시각적으로 확인할 수 있다.

※ DMZ 구역은 Open 등급에 해당하며, DMZ 내 시스템도 반드시 Open 등급으로 설정되어야 한다. AMADEUS는 이 규칙의 위반을 자동으로 탐지한다. (N2SF §2.3)

2.3 제3단계: 위협식별 (Identify) — 핵심 기능

위협식별 단계는 AMADEUS의 핵심 기능이 집중되는 단계이다. 가이드라인이 제시하는 「위치-주체-객체」 모델링 방법론과 보안원칙 적용을 Alloy 정형 검증 엔진으로 자동화한다.

AMADEUS 활용 가능 영역

활동	AMADEUS 활용
[활동-3-1] 모델링 및 C/S/O 평가	가이드라인의 「위치-주체-객체」 모델링을 ReactFlow 캔버스에서 수행한다. 시스템 간 연결을 정의하면 자동으로 C/S/O 등급 차이를 감지하여 보안등급 혼용 여부를 판단한다. 위치(Domain)·주체(Subject)·객체(Object)의 보안등급이 동일 등급에 위치하는지 자동 확인한다.
[활동-3-2] 보안원칙 적용	「정보 생산·저장」 보안원칙: 정보시스템의 보안등급보다 높은 등급의 업무정보가 생산·저장되는 것을 위협으로 식별한다. 「정보 이동」 보안원칙: 업무정보의 보안등급보다 낮은 등급의 정보시스템으로 이동이 발생하는 것을 위협으로 식별한다. Alloy 59개 규칙 + JS Validator 6개 규칙으로 자동화한다.
[활동-3-3] 보안위협 식별	정형 검증(Alloy) 결과로 서로 다른 보안등급 간 발생 가능한 구조적 보안위협을 자동 식별한다. 26개 N2SF 위협 코드 카테고리(LP, IV, IM, AC, MA, EI, DA, AU 등)로 분류하여 체계적으로 출력한다.

※ 가이드라인 p.46 [그림 2-9]의 「위치-주체-객체」 모델 평가표와 p.48~49의 보안원칙 적용 매트릭스가 AMADEUS의 Alloy 엔진이 수행하는 검증 로직에 해당한다.

2.4 제4단계: 보안대책 수립 (Select)

보안대책 수립 단계에서는 앞선 위협식별 단계에서 식별된 보안위험을 해소하기 위한 보안 요구사항을 도출하고, 보안 요구사항을 만족하는 관리적·기술적 수단으로서의 보안통제 항목을 선택한다.

AMADEUS 활용 가능 영역

활동	AMADEUS 활용
[활동-4-1] 보안 요구사항 도출	위협식별 결과에서 도출된 위협 코드가 곧 보안 요구사항이 된다. 예를 들어 N2SF-LP(최소권한) 위반이 탐지되면 접근권한 재정정이 필요하다는 보안 요구사항이 자동으로 도출된다.
[활동-4-2] 보안통제 선택	위협 코드가 N2SF 보안통제 항목 분류(부록1)에 직접 매핑된다. Score Dashboard에서 C/S/O 등급별 우선 검토사항과 연계하여 어떤 보안통제를 선택해야 하는지 가이드를 제공한다.

AMADEUS 위협 코드와 N2SF 보안통제 매핑 (일부)

위협 코드	N2SF 보안통제 분류	설명
LP	최소 권한 (Least Privilege)	정보시스템 접근 권한 정의 및 제한
IV	식별 및 인증 (ID Verification)	사용자 신원 확인 및 인증 메커니즘
IM	무결성 관리 (Integrity Mgmt)	데이터 및 시스템 무결성 보장
AC	접근 통제 (Access Control)	정보시스템 및 데이터 접근 제어
EI	암호화 (Encryption & Info)	전송 및 저장 데이터 암호화
DA	데이터 보호 (Data Assurance)	데이터 생명주기 보호
AU	감사 및 로깅 (Audit)	보안 이벤트 기록 및 모니터링
SN	네트워크 보안 (Secure Network)	네트워크 경계 및 통신 보안

2.5 제5단계: 적절성 평가·조정 (Assess)

적절성 평가·조정 단계에서는 준비, C/S/O 등급분류, 위협식별, 보안대책 수립의 전 과정에 대한 적절성을 평가하고, 미흡한 점에 대해서는 조정하여 보완한다.

AMADEUS 활용 가능 영역

활동	AMADEUS 활용
[활동-5-1] 적절성 평가	Score Dashboard의 검증 점수와 위협 목록을 평가 근거 자료로 활용할 수 있다. 가이드라인의 평가지표 중 "모델링 및 C/S/O 평가를 수행하였는가?", "보안원칙을 적용하였는가?" 등에 대한 증빙 자료를 제공한다.
[활동-5-2] 적절성 평가결과 협의·조정	모델을 수정한 후 재검증하면 조정 전후의 결과를 비교할 수 있다. 반복적인 평가·조정 사이클을 도구 내에서 직접 수행할 수 있다.

활동	AMADEUS 활용
[활동-5-3] 적절성 평가결과 확인	최종 검증이 통과된 모델을 JSON으로 Export하여 보안성 검토 산출물(자체 보안대책)의 근거 자료로 국가정보원에 제출할 수 있다.

3. 종합 평가

3.1 단계별 AMADEUS 기여도

단계	기여도	역할
1단계 준비 (Prepare)	★★☆☆☆	정보서비스 구조 시각화 보조
2단계 C/S/O 등급분류 (Categorize)	★★★★☆	시스템·구역별 등급 지정 및 정합성 검증
3단계 위협식별 (Identify)	★★★★★	핵심. 「위치-주체-객체」 모델링 + 보안원칙 적용 + 보안위협 식별을 정형 검증으로 자동화
4단계 보안대책 수립 (Select)	★★★★☆	위협 코드 → N2SF 보안통제 항목 매핑
5단계 적절성 평가·조정 (Assess)	★★★★☆	평가 근거 자료 생성 및 반복 검증 지원

3.2 AMADEUS의 핵심 가치

AMADEUS는 N2SF 5단계 중 제3단계(위협식별)를 중심으로 제2~4단계를 관통하는 도구이다. 가이드라인 본문에서 "모든 국가·공공기관에 공통적으로 적용할 수 있는 정보서비스 위협식별 방법론"으로 제시한 「위치-주체-객체」 모델링과 보안원칙 적용을 정형 검증(Formal Verification) 기반으로 자동화한다는 점이 핵심 가치이다.

이를 통해 다음과 같은 효과를 기대할 수 있다.

- 위협식별의 체계화: 수작업 모델링 대신 도구 기반의 정형 검증으로 누락 없는 위협 식별이 가능하다.
- 보안등급 혼용 자동 탐지: C/S/O 등급이 서로 다른 시스템 간의 연결에서 발생하는 구조적 보안위협을 즉시 식별한다.
- 보안대책 수립 효율화: 식별된 위협 코드가 N2SF 보안통제 항목에 직접 매핑되어 보안통제 선택 과정을 가속화한다.
- 반복 검증 용이: 모델 수정 후 재검증이 즉시 가능하여 적절성 평가·조정의 반복 사이클을 효율적으로 지원한다.
- 산출물 표준화: JSON 기반 모델 Export를 통해 국가정보원 보안성 검토 시 제출하는 자체 보안대책의 근거 자료를 체계적으로 생성한다.

3.3 N2SF 적용 절차에서의 AMADEUS 위치

구분	내용
도구 명칭	AMADEUS (Advanced Threat Modeling & Analysis Platform)
주요 적용 단계	제3단계 위협식별 (Identify) 중심, 제2~4단계 관통

구분	내용
검증 방식	Alloy 정형 검증 엔진 (59개 규칙) + JS 경량 검증기 (6개 규칙)
위협 분류 체계	N2SF 보안통제 26개 코드 카테고리
핵심 자동화 영역	「위치-주체-객체」모델링, C/S/O 평가, 「정보 생산·저장」원칙 적용, 「정보 이동」원칙 적용, 보안위협 식별
산출물	JSON 모델 파일, 위협 분석 보고서, 보안 점수 대시보드

본 문서는 「국가 망 보안체계 보안 가이드라인 v1.0」(국가정보원·NSR, 2025.9)을 기반으로 분석하였다.